# Sécurité informatique — menaces et protection

Informatique — Licence 2 (L2)

Cours INF-L2-12

Institut Africain de Management (IAM) — Bamako, Mali
Bibliothèque Universitaire — Bronbah Tech

**À propos de ce cours**

Comprendre les attaques pour mieux s'en défendre : panorama des menaces et des vulnérabilités, familles de malwares et désinfection, cryptographie symétrique et asymétrique, hachage et intégrité des données, pare-feu et politique de sécurité, Wi-Fi protégé et lutte contre l'ingénierie sociale — toujours du point de vue du défenseur.

Document pédagogique original créé pour les étudiants de l'IAM : leçons détaillées, exemples commentés, travaux dirigés et pratiques, exercices corrigés, QCM d'évaluation et vidéos recommandées. Aucun contenu n'est reproduit d'ouvrages existants.

# Sommaire

• Introduction à la matière
• Objectifs d'apprentissage
• Leçon 1 — Menaces et vulnérabilités : panorama des attaques courantes
• Leçon 2 — Malwares : familles, propagation et désinfection
• Leçon 3 — Cryptographie de base : chiffrement symétrique et asymétrique
• Leçon 4 — Hachage et intégrité des données
• Leçon 5 — Pare-feu, antivirus et politique de sécurité
• Leçon 6 — Sécurité des réseaux Wi-Fi
• Leçon 7 — Sensibilisation des utilisateurs et ingénierie sociale
• Travaux dirigés (TD)
• Travaux pratiques (TP)
• Exercices corrigés supplémentaires
• QCM d'évaluation
• Résumé — les notions importantes
• Vidéos associées aux leçons
• Sources et références

Comment utiliser ce cours : lis chaque leçon dans l'ordre, refais les exemples à la main, tente chaque exercice AVANT de lire son corrigé, puis termine par le QCM pour vérifier ce que tu as retenu.

# Introduction à la matière

En Licence 1, le cours d'hygiène numérique t'a appris les bons réflexes individuels : mots de passe robustes, double authentification, sauvegardes régulières. Ce cours de Licence 2 passe de l'autre côté du miroir — mais du bon côté : celui du défenseur. Pour protéger un système, il faut comprendre comment il peut être attaqué, quelles faiblesses les attaquants exploitent et quelles barrières techniques et humaines les arrêtent. Nous décrirons donc les attaques au niveau des concepts et des mécanismes généraux, jamais sous forme de modes d'emploi : le but est de savoir les reconnaître, les évaluer et les bloquer, pas de les reproduire. Penser comme un défenseur, c'est se demander en permanence : qu'est-ce qui a de la valeur ici, qui pourrait en vouloir, par où passerait-il, et quelle protection raisonnable puis-je mettre en place avec les moyens dont je dispose ?

Trois piliers structurent le cours. D'abord, l'analyse : distinguer une menace d'une vulnérabilité, évaluer un risque, connaître les familles de logiciels malveillants et les grandes catégories d'attaques, du déni de service à l'homme du milieu. Ensuite, la cryptographie, qui fournit les outils mathématiques de la protection : le chiffrement pour la confidentialité, le hachage pour l'intégrité, les signatures pour l'authenticité — trois outils souvent confondus, que nous prendrons soin de distinguer avec des calculs réels à l'appui. Enfin, l'organisation : pare-feu réglé selon le moindre privilège, politique de sécurité écrite, Wi-Fi correctement configuré et utilisateurs sensibilisés. Un système sûr n'est jamais le produit d'un seul outil miracle, mais de couches de défense qui se complètent et se rattrapent les unes les autres quand l'une d'elles cède.

Ce cours reste volontairement défensif, concret et mesuré. Chaque leçon se termine par des mesures applicables à un poste personnel, au réseau d'une petite entreprise ou à celui d'un établissement comme l'IAM, avec des budgets réalistes : la plupart des protections décisives sont des réglages, des habitudes et des procédures, pas des achats. Les exemples de cryptographie sont calculés réellement — les empreintes SHA-256 citées ont été produites avec Python, pour que tu puisses les reproduire sur ta machine et constater toi-même l'effet avalanche. Le TP final te fera auditer ton propre poste et ton propre Wi-Fi, jamais ceux d'autrui. À la fin du cours, tu sauras évaluer la sécurité d'une petite infrastructure, proposer des corrections argumentées par le risque, et expliquer calmement, sans jargon inutile, pourquoi chaque mesure compte.

## Objectifs d'apprentissage

À la fin de ce cours, tu seras capable de :

- Distinguer menace, vulnérabilité et risque, et classer les attaques courantes (hameçonnage, déni de service, force brute, homme du milieu).
- Identifier les grandes familles de malwares, leurs modes de propagation et les étapes d'une désinfection prudente.
- Expliquer la différence entre chiffrement symétrique et asymétrique, et le rôle exact des clés publique et privée.
- Calculer une empreinte SHA-256 et l'utiliser pour vérifier l'intégrité d'un fichier ou protéger un mot de passe salé.
- Lire et rédiger des règles de pare-feu simples selon le principe du moindre privilège.
- Configurer un réseau Wi-Fi domestique de façon sûre : WPA3 ou WPA2, mot de passe robuste, WPS désactivé, firmware à jour.
- Reconnaître les leviers psychologiques de l'ingénierie sociale et appliquer les réflexes de vérification qui la déjouent.

## Leçon 1 — Menaces et vulnérabilités : panorama des attaques courantes

Trois mots sont à distinguer dès le départ, car les confondre empêche de raisonner juste. Une menace est un danger potentiel : un pirate, un employé malveillant, un logiciel malveillant, parfois même un événement naturel comme une inondation du local serveur. Une vulnérabilité est une faiblesse du système : un logiciel non mis à jour, un mot de passe faible, un port ouvert inutilement, un utilisateur mal formé. Le risque naît de la rencontre des deux : c'est la probabilité qu'une menace exploite une vulnérabilité, multipliée par la gravité des dégâts. Toute la sécurité consiste à réduire les vulnérabilités et à limiter l'impact quand une attaque réussit malgré tout.

Les attaques visent trois propriétés fondamentales, résumées par le sigle CID. La confidentialité : que seuls les ayants droit lisent les données — une attaque la viole en espionnant ou en volant des fichiers. L'intégrité : que les données ne soient pas modifiées sans autorisation — un attaquant qui change un prix ou un relevé de notes l'attaque. La disponibilité : que le service reste accessible — un déni de service, qui

sature une machine de requêtes pour la rendre inutilisable, la vise directement. À cela s'ajoutent souvent l'authenticité (être sûr de l'identité de son interlocuteur) et la non-répudiation (ne pas pouvoir nier une action accomplie).

Parmi les attaques courantes, citons le hameçonnage (phishing), qui trompe l'utilisateur pour lui voler ses identifiants ; l'attaque par force brute, qui essaie systématiquement des mots de passe jusqu'à trouver le bon ; l'homme du milieu, qui s'intercale dans une communication pour l'écouter ou la modifier ; l'exploitation de failles, qui tire parti d'un logiciel non corrigé ; et l'injection, qui glisse des commandes dans les formulaires mal protégés d'un site. Aucune n'est magique : chacune exploite une faiblesse précise — technique ou humaine. C'est une bonne nouvelle : pour chaque faiblesse, il existe une parade, et c'est l'objet de ce cours.

**L'essentiel**
Menace = danger potentiel ; vulnérabilité = faiblesse exploitable ; risque = probabilité × impact. Les attaques visent la confidentialité, l'intégrité ou la disponibilité (CID). Chaque attaque exploite une faiblesse identifiable, donc corrigeable.

## Exemple — Grille d'analyse d'un scénario (petite boutique en ligne)

```
SCENARIO : boutique en ligne d'une PME, site heberge sur un
serveur, base de commandes, paiements par mobile money.

Actif | Menace | Vulnerabilite | Mesure defensive
--------------+------------------+----------------------+--------------------
Base commandes | Vol de donnees | Mots de passe faibles| Mots de passe longs
| | et partages | + double authent.
Serveur web | Defacement, | Logiciel non mis | Mises a jour auto-
| indisponibilite | a jour depuis 1 an | matiques + correctifs
Poste du gerant| Hameconnage | Aucune formation | Sensibilisation +
| | des employes | filtre anti-phishing
Fichiers | Ranc¸ongiciel | Aucune sauvegarde | Sauvegarde 3-2-1
| | externe | testee chaque mois

Lecture : on protege d'abord la ou le risque (probabilite x
impact) est le plus eleve, pas la ou l'outil est le plus cher.
```

## À retenir

- Risque = probabilité qu'une menace exploite une vulnérabilité × gravité de l'impact.
- CID : confidentialité, intégrité, disponibilité — les trois propriétés à protéger.
- On corrige des vulnérabilités concrètes, on ne « lutte » pas contre des menaces abstraites.

## Exercice

Pour chacun de ces trois cas, identifie la menace, la vulnérabilité et la propriété CID principalement visée, puis propose une mesure défensive : (1) un étudiant se connecte au Wi-Fi ouvert d'un café et consulte sa messagerie professionnelle sans VPN ; (2) le

site d'une association utilise un mot de passe d'administration « admin123 » inchangé depuis l'installation ; (3) un disque dur unique contient toutes les photos d'un studio, sans copie ailleurs.

**✔ Corrigé**
Cas 1 — Menace : un attaquant présent sur le même réseau ouvert, en position d'homme du milieu. Vulnérabilité : trafic non chiffré sur un réseau non maîtrisé. Propriété visée : la confidentialité (et l'authenticité). Mesures : éviter les opérations sensibles sur Wi-Fi public, utiliser un VPN, vérifier le HTTPS. Cas 2 — Menace : un attaquant qui tente les mots de passe par défaut, connus de tous. Vulnérabilité : identifiants par défaut et faibles. Propriété visée : l'intégrité et la confidentialité (prise de contrôle du site). Mesures : mot de passe long et unique, double authentification, comptes nominatifs. Cas 3 — Menace : panne du disque, vol ou rançongiciel. Vulnérabilité : copie unique des données. Propriété visée : la disponibilité. Mesure : sauvegarde 3-2-1 (trois copies, deux supports, une hors site), testée régulièrement.

# Leçon 2 — Malwares : familles, propagation et désinfection

Malware (de « malicious software ») est le terme générique des logiciels malveillants. Le virus s'attache à un fichier ou un programme sain et se déclenche quand celui-ci est exécuté ; il lui faut donc un hôte et, souvent, un geste de l'utilisateur. Le ver, au contraire, se propage tout seul de machine en machine en exploitant les failles des réseaux : il n'a besoin d'aucun clic, ce qui explique sa rapidité. Le cheval de Troie se déguise en logiciel utile ou amusant — jeu gratuit, fausse facture, application « crackée » — pour que la victime l'installe elle-même : la ruse remplace la faille technique.

D'autres familles se définissent par leur objectif. Le rançongiciel (ransomware) chiffre les fichiers de la victime et exige un paiement pour promettre la clé de déchiffrement : les autorités recommandent de ne pas payer, car rien ne garantit la restitution et le paiement finance la criminalité — les sauvegardes sont la vraie parade. Le logiciel espion (spyware) surveille et transmet des informations : frappes du clavier (enregistreur de frappes), écrans, fichiers. Le rootkit cherche à se rendre presque invisible en se cachant profondément dans le système, ce qui rend sa détection et son retrait difficiles. Enfin, les machines infectées peuvent être enrôlées dans un réseau de machines zombies (botnet) piloté à distance, par exemple pour saturer un site par déni de service distribué.

Les voies d'entrée sont presque toujours les mêmes : pièce jointe ou lien de courriel trompeur, téléchargement de logiciels « gratuits » sur des sites douteux, clés USB inconnues branchées sans précaution, logiciels non mis à jour dont les failles sont publiquement connues. La désinfection suit une procédure calme : débrancher la machine du réseau pour stopper la propagation et les fuites ; ne plus l'utiliser pour des opérations sensibles ; lancer une analyse complète avec un antivirus à jour, si besoin en mode sans échec ou depuis un support de démarrage sain ; en cas de doute sérieux, réinstaller le système proprement et restaurer les données depuis une sauvegarde saine ; enfin, changer les mots de passe importants depuis un appareil

sain et tirer la leçon de l'incident (quelle porte d'entrée ? quelle correction ?).

**L'essentiel**
Virus = attaché à un hôte ; ver = autonome sur le réseau ; cheval de Troie = déguisé ; rançongiciel = chiffrement + extorsion ; espion = surveillance ; rootkit = dissimulation. Désinfecter : isoler, analyser, réinstaller si besoin, restaurer la sauvegarde, changer les mots de passe.

## Exemple — Chaîne d'infection typique… et où la défense la casse

```
ETAPE DE L'ATTAQUE | PARADE DU DEFENSEUR
---------------------------------+---------------------------------
1. Courriel trompeur avec | Filtre anti-phishing +
piece jointe « facture.pdf » | sensibilisation : verifier
| l'expediteur avant d'ouvrir
2. L'utilisateur ouvre la piece | Antivirus a jour : analyse
jointe, le code s'execute | en temps reel, macros des-
| activees par defaut
3. Le malware cherche d'autres | Reseau segmente, partages
machines du reseau local | limites au strict necessaire
4. Il chiffre les fichiers | Sauvegardes 3-2-1 dont une
accessibles et affiche une | copie hors ligne : on res-
demande de rançon | taure sans payer
5. Il exfiltre des donnees | Pare-feu sortant, droits
| limites, mots de passe uniques

Une seule parade peut echouer ; c'est l'empilement qui protege.
```

## À retenir

- Le vecteur d'entrée n°1 reste l'utilisateur trompé : pièce jointe, lien, faux logiciel « gratuit ».
- Face à un rançongiciel : ne pas payer ; isoler, restaurer les sauvegardes, signaler.
- Désinfection méthodique : isoler → analyser → réinstaller si doute → restaurer → changer les mots de passe.

## Exercice

Un collègue t'appelle : il a ouvert une pièce jointe « Relevé.pdf » reçue par courriel, son ordinateur est devenu très lent et certains fichiers ont maintenant une extension inconnue. Décris, dans l'ordre, les cinq premières actions que tu lui conseilles, et justifie chacune en une phrase.

**✔ Corrigé**
1) Débrancher immédiatement le câble réseau et couper le Wi-Fi : on stoppe la propagation vers les autres machines et l'envoi de données vers l'extérieur. 2) Ne pas éteindre brutalement ni tenter de payer quoi que ce soit : on conserve les traces utiles et on ne finance pas les criminels. 3) Ne plus saisir aucun mot de passe important sur cette machine : elle peut contenir un enregistreur de frappes. 4) Lancer une analyse antivirus complète depuis un environnement sain (mode sans échec ou support de démarrage) : certains malwares se cachent du système en fonctionnement normal. 5) Si les fichiers sont chiffrés ou si le doute persiste : réinstaller le système, restaurer les données depuis la sauvegarde la plus récente et saine, puis changer les mots de passe importants depuis un appareil sain. Ensuite seulement, analyser la porte d'entrée (ici, le courriel) pour corriger la cause.

# Leçon 3 — Cryptographie de base : chiffrement symétrique et asymétrique

La cryptographie transforme un message lisible (le texte clair) en message illisible (le texte chiffré) au moyen d'un algorithme et d'une clé ; seul le détenteur de la bonne clé peut revenir au texte clair : c'est le déchiffrement. L'exemple historique le plus simple est le chiffrement de César : chaque lettre est décalée d'un nombre fixe de positions dans l'alphabet. C'est un excellent jouet pédagogique, mais une protection nulle : il n'existe que 25 décalages utiles, qu'un enfant épuise en quelques minutes. Les algorithmes modernes reposent sur le principe de Kerckhoffs : l'algorithme est public et examiné par les experts, seule la clé est secrète — et l'espace des clés est si immense que les essayer toutes prendrait des milliards d'années.

Dans le chiffrement symétrique, la même clé sert à chiffrer et à déchiffrer, comme la clé d'une maison que deux correspondants se partagent. L'algorithme de référence est AES (Advanced Encryption Standard), rapide et utilisé partout : disques chiffrés, Wi-Fi, messagerie. Sa limite n'est pas mathématique mais logistique : comment transmettre la clé secrète à son correspondant sans qu'un espion l'intercepte ? Et dans un groupe de cent personnes, il faudrait une clé par paire, soit près de cinq mille clés. Le chiffrement symétrique est donc excellent pour protéger de gros volumes de données… une fois le problème de l'échange de clé résolu.

Le chiffrement asymétrique, inventé dans les années 1970 (Diffie-Hellman, puis RSA), utilise une paire de clés liées mathématiquement : une clé publique, que l'on distribue à tout le monde, et une clé privée, que l'on ne partage jamais. Ce qui est chiffré avec la clé publique ne peut être déchiffré qu'avec la clé privée correspondante : n'importe qui peut donc t'écrire de façon confidentielle, toi seul peux lire. Le mécanisme sert aussi, dans l'autre sens, à la signature numérique : on « signe » avec sa clé privée, tout le monde vérifie avec la clé publique. Comme l'asymétrique est lent, les systèmes réels comme HTTPS combinent les deux mondes : l'asymétrique sert à échanger en sécurité une clé de session, puis le symétrique (AES) chiffre la conversation.

**L'essentiel**
Symétrique : une seule clé partagée (AES), rapide mais échange délicat. Asymétrique : clé publique pour chiffrer, clé privée — jamais partagée — pour déchiffrer ; la clé privée signe, la clé publique vérifie. HTTPS combine les deux : échange asymétrique, puis session symétrique.

## Exemple — Le chiffrement de César, un jouet qui montre ses limites

```
PRINCIPE : decaler chaque lettre de K positions (A -> D si K=3)

Message clair : BONJOUR
Decalage K = 3 : B->E, O->R, N->Q, J->M, O->R, U->X, R->U
Message chiffre : ERQMRXU

Autre exemple : RENDEZVOUS avec K = 5 donne WJSIJEATZX.

POURQUOI C'EST FAIBLE :
- Seulement 25 cles possibles : on les essaie toutes en
quelques minutes (attaque par force brute triviale).
- La frequence des lettres trahit le texte : en francais,
le E est la lettre la plus frequente ; la lettre la plus
frequente du texte chiffre est donc presque surement E.

LECON : un bon algorithme moderne (AES, RSA) garde un
espace de cles immense et ne laisse pas de motifs visibles.
La cle est secrete, l'algorithme est public (Kerckhoffs).
```

## À retenir

- Chiffrer protège la confidentialité ; déchiffrer exige la bonne clé, et elle seule.
- Clé publique = distribuée, sert à chiffrer (et à vérifier les signatures) ; clé privée = secrète, sert à déchiffrer (et à signer).
- En pratique : asymétrique pour échanger la clé, symétrique pour chiffrer les données (HTTPS).

## Exercice

Aïcha veut envoyer un message confidentiel à Bakary, et Bakary veut être certain qu'un document vient bien d'Aïcha. Pour chaque besoin, dis quelle clé est utilisée par qui : (1) Aïcha chiffre son message — avec quelle clé ? (2) Bakary déchiffre — avec quelle clé ? (3) Aïcha signe son document — avec quelle clé ? (4) Bakary vérifie la signature — avec quelle clé ?

**✔ Corrigé**
(1) Aïcha chiffre avec la clé PUBLIQUE de Bakary : tout le monde la connaît, elle ne sert qu'à fermer le « cadenas ». (2) Bakary déchiffre avec sa clé PRIVÉE, qu'il est le seul à posséder : c'est le principe même de l'asymétrique. (3) Aïcha signe avec sa propre clé PRIVÉE : elle seule peut produire cette signature, ce qui l'engage. (4) Bakary vérifie avec la clé PUBLIQUE d'Aïcha : si la vérification passe, le document vient bien du détenteur de la clé privée correspondante et n'a pas été modifié. Erreur classique à éviter : croire qu'on chiffre « avec sa clé privée pour que ce soit secret » — ce qui est produit avec une clé privée peut être lu/vérifié par tous ceux qui ont la clé publique : cela prouve l'origine (signature), cela ne cache rien.

# Leçon 4 — Hachage et intégrité des données

Une fonction de hachage transforme des données de n'importe quelle taille en une empreinte de taille fixe — 256 bits, soit 64 caractères hexadécimaux, pour SHA-256. Elle possède des propriétés remarquables : elle est déterministe (la même entrée donne toujours la même empreinte), rapide à calculer, et surtout à sens unique : retrouver le message d'origine à partir de l'empreinte est pratiquement impossible. Elle présente aussi un « effet avalanche » : modifier un seul caractère du message change environ la moitié des caractères de l'empreinte, comme tu le vérifieras dans l'exemple. Point capital : le hachage n'est PAS un chiffrement — il n'y a ni clé, ni moyen de revenir en arrière ; il ne cache pas, il « scelle ».

L'usage le plus concret est la vérification d'intégrité : tu télécharges un logiciel, le site publie l'empreinte officielle du fichier ; tu calcules l'empreinte du fichier reçu et tu compares. Si un seul bit a été modifié pendant le transfert — ou pire, si un attaquant a remplacé le fichier par une version piégée — les empreintes diffèrent et tu le détectes. Deuxième usage, tout aussi quotidien : le stockage des mots de passe. Un site sérieux ne conserve jamais les mots de passe en clair, mais leur empreinte, idéalement avec un « sel » (une valeur aléatoire propre à chaque compte) et une fonction volontairement lente comme bcrypt ou Argon2, pour décourager les essais massifs en cas de vol de la base.

Le hachage a ses limites et son histoire. Les anciens algorithmes MD5 et SHA-1 sont aujourd'hui déconseillés pour la sécurité : des collisions — deux messages différents donnant la même empreinte — y ont été démontrées, ce qui casse la garantie d'intégrité. Par ailleurs, une empreinte seule prouve qu'un fichier n'a pas changé depuis le calcul, mais pas QUI l'a produit : pour l'authenticité, il faut une signature numérique ou un code d'authentification (HMAC) qui combine hachage et clé secrète. Retenir la distinction entre ces outils — chiffrement pour cacher, hachage pour sceller, signature pour prouver l'origine — évite la plupart des confusions en sécurité.

**L'essentiel**
Hachage = empreinte fixe, déterministe, à sens unique, avec effet avalanche. Ce n'est pas un chiffrement : pas de clé, pas de retour. SHA-256 est l'algorithme de référence ; MD5 et SHA-1 sont à abandonner. Mots de passe : empreinte + sel + fonction lente (bcrypt, Argon2).

## Exemple — Calculer des empreintes SHA-256 avec Python (résultats réels)

```
import hashlib

def empreinte(texte):
return hashlib.sha256(texte.encode("utf-8")).hexdigest()

print(empreinte("Bonjour IAM"))
# 9a8c61830f4b5d7a636ba5848313dc8adc17354ef72dc6a2c8dae70c90e8b240

print(empreinte("Bonjour IAM!"))
# 1250e81afdc4f4de2a39d3184fc42d1de88f0a3aced27dfb66dd5b4e04a44c08

# Un seul caractere ajoute (« ! ») et 63 des 64 caracteres
# hexadecimaux de l'empreinte changent : effet avalanche.

print(empreinte("IAM"))
# 7c6826445eb63c221233eae6d2d98f14b6b9e5b50abb9eefc83fc967dfa28382

# Verification d'integrite d'un fichier telecharge :
# on compare l'empreinte calculee chez soi a celle publiee
# par l'editeur. Differentes => fichier modifie, a refuser.
```

## À retenir

- Même entrée → même empreinte ; entrée légèrement différente → empreinte méconnaissable.
- On ne « déchiffre » pas une empreinte : le hachage est irréversible par conception.
- Intégrité des fichiers, mots de passe salés : deux usages quotidiens du hachage.

## Exercice

Un éditeur publie l'empreinte SHA-256 de son logiciel : b701a776b3ce547f769e733f2d695779caacee2ba1c3465ea34cbcdcf8fa18ad. Après téléchargement, tu calcules : 05c12bc7099cad475a1d178e5fc6e4f4182a3a219eb4500a0823867894a9ba33. (1) Que conclus-tu ? (2) Ces deux empreintes correspondent en réalité au contenu « Rapport de stage - etudiant IAM - version finale » et au même texte suivi d'un simple espace : que cela illustre-t-il ? (3) Un site stocke les mots de passe avec MD5 sans sel : cite deux problèmes.

**✔ Corrigé**
(1) Les empreintes diffèrent : le fichier reçu n'est pas identique au fichier officiel. Il a pu être corrompu pendant le transfert ou, plus grave, remplacé par une version malveillante : on ne l'installe pas, on re-télécharge depuis la source officielle et on refait la comparaison. (2) Cela illustre l'effet avalanche : une modification minuscule et invisible (un espace en fin de texte) produit une empreinte totalement différente — c'est exactement ce qui rend la comparaison d'empreintes fiable pour détecter toute altération. (3) Problème un : MD5 est rapide et les ordinateurs actuels peuvent essayer des milliards de candidats par seconde, ce qui rend les mots de passe faibles retrouvables par force brute ou tables précalculées ; de plus MD5 admet des collisions démontrées. Problème deux : sans sel, deux utilisateurs ayant le même mot de passe ont la même empreinte, et une empreinte volée se compare directement à des listes de mots de passe courants déjà hachés. La bonne pratique : sel unique par compte et fonction lente conçue pour cela (bcrypt, Argon2, scrypt).

# Leçon 5 — Pare-feu, antivirus et politique de sécurité

Le pare-feu (firewall) est le gardien des frontières du réseau : il examine le trafic qui entre et qui sort, et applique des règles — autoriser ou bloquer — selon l'adresse source, l'adresse de destination, le port et le protocole. La posture sûre est le « tout interdire par défaut, puis autoriser explicitement le nécessaire » : un service non autorisé reste fermé, même si on l'installe par erreur. Les pare-feu modernes sont aussi « à états » : ils retiennent qu'une connexion sortante légitime a été établie, et laissent revenir sa réponse sans ouvrir de porte permanente. On trouve des pare-feu logiciels sur chaque machine (celui de Windows ou de Linux) et des pare-feu matériels ou réseau qui protègent tout un parc.

L'antivirus, lui, surveille les fichiers et les comportements sur la machine elle-même. Les moteurs classiques comparent les fichiers à une base de signatures de malwares connus — d'où l'importance vitale des mises à jour, car un antivirus périmé ne connaît pas les menaces récentes. Les générations actuelles (souvent appelées EDR dans les entreprises) ajoutent l'analyse comportementale : un programme qui se met soudain à chiffrer des centaines de fichiers déclenche une alerte même s'il n'est pas dans la base. Mais aucun antivirus n'est un bouclier absolu : il ne corrige ni les mots de passe faibles, ni les failles des logiciels non mis à jour, ni la naïveté face à un courriel bien imité. C'est une couche, pas la muraille entière.

Ces outils prennent leur sens dans une politique de sécurité : un document, même simple, qui fixe les règles du jeu d'une organisation — qui a accès à quoi (principe du moindre privilège : chacun ne reçoit que les droits nécessaires à son travail), comment les comptes sont créés et supprimés, quelles mises à jour sont obligatoires, comment les sauvegardes sont faites et testées, que faire en cas d'incident. Sans politique, la sécurité dépend des humeurs du moment ; avec elle, les décisions deviennent cohérentes et vérifiables. Pour une petite structure, deux pages de règles écrites, connues de tous et relues chaque semestre, valent mieux qu'un classeur parfait que personne n'ouvre.

**L'essentiel**
Pare-feu = filtre du trafic selon des règles, posture « interdire par défaut ». Antivirus = signatures + comportement, à jour ou presque inutile. Politique de sécurité = les règles écrites de l'organisation ; moindre privilège pour les droits d'accès.

## Exemple — Règles de pare-feu commentées pour un petit réseau

```
POLITIQUE PAR DEFAUT : tout trafic non explicitement
AUTORISE est BLOQUE (entrant comme sortant).

N° | Sens | Source -> Destination | Port | Decision
---+---------+---------------------------+------+----------
1 | Sortant | Postes -> Internet | 443 | AUTORISER
| | (navigation web securisee) | |
2 | Sortant | Postes -> Internet | 53 | AUTORISER
| | (resolution de noms DNS) | |
3 | Entrant | Internet -> Serveur web | 443 | AUTORISER
| | (le site public, et lui) | |
4 | Entrant | Internet -> Serveur web | 22 | BLOQUER
| | (administration SSH : | |
| | jamais expose a Internet) | |
5 | Entrant | Internet -> Postes | tous | BLOQUER
| | (aucun poste n'est un | |
| | serveur public) | |

Lecture : chaque autorisation repond a un besoin nomme.
Tout le reste est bloque par defaut, y compris les
services « oublies » : c'est le moindre privilege reseau.
```

## À retenir

- Règle d'or du pare-feu : interdire par défaut, autoriser nommément le nécessaire.
- Un antivirus non mis à jour ne connaît pas les menaces récentes : mise à jour automatique obligatoire.
- Moindre privilège : chaque compte, chaque règle ne donne que le strict nécessaire.

## Exercice

Une école possède : un serveur de fichiers interne, des postes enseignants, des postes élèves et un site web public hébergé à l'extérieur. Propose trois règles de pare-feu (sens, source, destination, port, décision) et justifie-les, dont une qui protège spécialement le serveur de fichiers.

**✔ Corrigé**
Règle 1 (protection du serveur de fichiers) : Entrant Internet → serveur de fichiers, tous ports : BLOQUER. Le serveur de fichiers est interne par nature ; il ne doit être joignable que depuis le réseau local, jamais depuis Internet. Règle 2 : Sortant postes élèves → Internet, port 443 : AUTORISER, pour la navigation web pédagogique en HTTPS ; tout autre trafic sortant des élèves reste bloqué par défaut. Règle 3 : Réseau élèves → réseau enseignants/serveurs, tous ports : BLOQUER, sauf le service précis dont les élèves ont besoin (par exemple l'impression) ; cette segmentation empêche qu'un poste élève infecté atteigne directement les postes enseignants ou l'administration du réseau. Chaque règle répond à un besoin nommé, conformément au principe du moindre privilège.

# Leçon 6 — Sécurité des réseaux Wi-Fi

Un réseau Wi-Fi diffuse ses ondes à travers les murs : quiconque est à portée peut tenter d'écouter ou de se connecter. La sécurité repose d'abord sur le protocole de chiffrement du lien. Les anciens WEP (cassé en quelques minutes) et WPA (première génération, fragilisée) sont à proscrire ; WPA2 avec un mot de passe long reste acceptable, et WPA3, le plus récent, renforce encore la protection, notamment contre les essais de mots de passe répétés et sur les réseaux ouverts. Un réseau totalement ouvert — sans mot de passe — laisse le trafic non chiffré par le Wi-Fi lui-même à la merci de l'écoute locale : la confidentialité dépend alors entièrement du HTTPS des sites visités.

Le protocole ne fait pas tout : la plupart des failles domestiques sont des fautes de configuration. Le mot de passe du Wi-Fi doit être long et unique — jamais le nom de famille suivi d'une date de naissance. Le mot de passe d'administration de la box, souvent laissé à sa valeur par défaut imprimée ou connue, doit être changé : c'est lui qui commande tous les réglages. La fonction WPS, qui connecte un appareil par un court code ou un bouton, a montré de sérieuses faiblesses et se désactive. Le firmware de la box se met à jour comme un logiciel. Enfin, un réseau « invités » séparé accueille les visiteurs et les objets connectés, sans accès aux ordinateurs et fichiers de la maison ou du bureau.

Hors de chez soi, la prudence change d'échelle : les Wi-Fi publics (cafés, gares, hôtels) sont des réseaux que l'on ne maîtrise pas, où un attaquant peut observer le trafic non chiffré ou créer un faux point d'accès au nom rassurant (« WiFi-Gratuit »). Les bons réflexes : privilégier la connexion mobile de son téléphone ou le partage de connexion personnel ; éviter les opérations sensibles (banque, administration) sur un réseau inconnu ; utiliser un VPN qui chiffre tout le trafic jusqu'à un serveur de confiance ; vérifier que les sites sont bien en HTTPS ; et désactiver la connexion automatique aux réseaux ouverts, qui fait entrer le téléphone dans le premier réseau venu.

**L'essentiel**
WPA3, à défaut WPA2, jamais WEP ni réseau ouvert pour des usages sensibles. Box : mot de passe Wi-Fi long et unique, mot de passe admin changé, WPS désactivé, firmware à jour, réseau invités séparé. Sur Wi-Fi public : VPN, HTTPS, pas d'opérations sensibles.

## Exemple — Check-list de sécurisation d'une box domestique

```
A FAIRE UNE FOIS, PUIS A VERIFIER CHAQUE SEMESTRE :

[ ] 1. Changer le mot de passe d'ADMINISTRATION de la box
(celui par defaut, souvent imprime, est connu).
[ ] 2. Choisir WPA3 si disponible, sinon WPA2 (AES).
Bannir WEP et WPA premiere generation.
[ ] 3. Mot de passe Wi-Fi : long (16 caracteres ou plus),
unique, ni nom ni date de naissance. Exemple de
methode : une phrase de 4 mots sans rapport.
[ ] 4. Desactiver le WPS (code court trop faible).
[ ] 5. Mettre a jour le firmware de la box, ou activer
ses mises a jour automatiques.
[ ] 6. Activer le reseau « invites » pour les visiteurs
et les objets connectes : ils ne verront pas les
ordinateurs ni les fichiers partages.
[ ] 7. Renommer le reseau (SSID) sans indiquer ni son
nom, ni son adresse, ni le modele de la box.

Sur un Wi-Fi PUBLIC : VPN active, HTTPS verifie,
aucune operation bancaire ou administrative.
```

## À retenir

- Le chiffrement du Wi-Fi se choisit : WPA3 > WPA2 >> WPA > WEP (à bannir).
- Les fautes les plus fréquentes sont des réglages par défaut non changés, pas des failles exotiques.
- Wi-Fi public = réseau hostile par prudence : VPN et HTTPS, rien de sensible.

## Exercice

Voici la configuration du Wi-Fi d'un petit cabinet : protocole WEP ; mot de passe « cabinet2020 » ; WPS activé ; mot de passe d'administration de la box jamais changé ; aucun réseau invités, les clients se connectent au même réseau que les dossiers. Relève au moins quatre problèmes et donne, pour chacun, la correction.

**✔ Corrigé**
1) WEP : protocole cassé depuis longtemps, un attaquant à portée peut retrouver la clé rapidement. Correction : passer en WPA3, ou WPA2-AES à défaut. 2) Mot de passe « cabinet2020 » : court, formé d'un mot du dictionnaire et d'une année, donc devinable par essais automatisés. Correction : phrase longue et unique (16 caractères ou plus). 3) WPS activé : son code court présente des faiblesses connues. Correction : le désactiver, la connexion par mot de passe suffit. 4) Mot de passe d'administration par défaut : il donne le contrôle total de la box à quiconque connaît la valeur d'usine du modèle. Correction : le changer pour un mot de passe distinct de celui du Wi-Fi. 5) Pas de réseau invités : les clients accèdent au même réseau que les dossiers du cabinet, ce qui viole le moindre privilège. Correction : activer le réseau invités isolé du réseau interne. Chacune de ces corrections est gratuite et prend quelques minutes : la sécurité Wi-Fi est d'abord une affaire de réglages.

# Leçon 7 — Sensibilisation des utilisateurs et ingénierie sociale

L'ingénierie sociale est l'art de pirater les humains plutôt que les machines : obtenir un mot de passe, un code ou un geste (un clic, un virement) en manipulant la confiance. Ses leviers psychologiques sont constants : l'urgence (« votre compte sera fermé dans deux heures »), l'autorité (« ici la direction, exécutez sans discuter »), la peur (« une activité suspecte a été détectée »), la curiosité (« regardez cette photo de vous »), la sympathie ou l'appât du gain. Le message frauduleux est conçu pour court-circuiter la réflexion : il pousse à agir vite, dans l'émotion, avant que le doute n'ait le temps de naître. Reconnaître ces leviers est déjà une défense : un message qui presse et qui fait peur doit déclencher de la méfiance, pas de l'obéissance.

Les formes sont variées : hameçonnage par courriel ou SMS, appel téléphonique d'un faux technicien ou d'un faux banquier (vishing), message d'un « directeur » demandant un virement urgent et confidentiel, fausse page de connexion imitant un service connu, clé USB « perdue » dans un parking qui excite la curiosité. Le point commun : l'attaquant n'a pas forcé la serrure technique, il a convaincu quelqu'un d'ouvrir la porte. C'est pourquoi les investissements purement logiciels ne suffisent jamais : le pare-feu le plus strict ne peut rien contre un utilisateur qui dicte son code de double authentification à un inconnu au téléphone.

La parade est culturelle autant que technique. D'abord, vérifier par un autre canal : rappeler la personne à son numéro connu, ouvrir le site officiel en tapant soi-même son adresse, ne jamais utiliser le lien ou le numéro fourni par le message suspect. Ensuite, installer des procédures : un virement inhabituel se confirme toujours par une deuxième personne ; aucun service sérieux ne demande un mot de passe ou un code complet par téléphone ou par courriel. Enfin, créer une culture du signalement sans honte : dans une organisation, l'employé qui déclare vite « je crois que j'ai cliqué » permet de limiter les dégâts, tandis que celui qui cache sa faute par peur laisse l'attaque prospérer. La sensibilisation régulière — exemples récents, simulations encadrées, rappels courts — transforme le maillon faible en première ligne de défense.

**L'essentiel**
Ingénierie sociale = manipuler l'humain (urgence, autorité, peur, curiosité) pour obtenir identifiants, codes ou gestes. Défenses : vérifier par un canal indépendant, procédures de double confirmation, double authentification, culture du signalement sans honte.

## Exemple — Grille d'analyse d'un message frauduleux (exemple inventé)

```
MESSAGE REÇU (INVENTE POUR CE COURS) :
« URGENT - Banque Atlantique Securite : une connexion
suspecte a ete detectee sur votre compte. Sans verifica-
tion sous 2 heures, votre compte sera DEFINITIVEMENT
BLOQUE. Cliquez ici : http://banque-atlantique-secu.example
/verif et entrez votre identifiant, votre mot de passe
et le code recu par SMS. »

GRILLE D'ANALYSE :
Signal d'alerte | Pourquoi c'est suspect
--------------------------------+-------------------------
Urgence extreme (« 2 heures », | Fabriquee pour empecher
« DEFINITIVEMENT » en capitales)| de reflechir : levier peur
Lien vers un domaine inconnu | La vraie banque utilise
(« -secu.example ») | son domaine officiel
Demande du mot de passe ET du | Aucun service serieux ne
code SMS dans la meme page | demande ces deux secrets
Ton menacant, fautes discretes | Les services clients ne
| menacent pas leurs clients

CONDUITE A TENIR : ne pas cliquer, ouvrir le site ou
l'application officielle par soi-meme, ou appeler le
numero officiel. Signaler le message, puis le supprimer.
```

## À retenir

- Urgence + peur + demande de secrets = signature presque certaine d'une manipulation.
- Toujours vérifier par un canal indépendant : jamais le lien ni le numéro du message suspect.
- Signaler vite n'est pas avouer une faute, c'est protéger tout le monde.

## Exercice

Un étudiant reçoit sur son téléphone : « Colis en attente : des frais de 1 500 F sont requis pour débloquer la livraison. Payez ici : [lien raccourci] ». Il attend effectivement un colis. (1) Quels signaux doivent l'alerter malgré la coïncidence ? (2) Quelle vérification indépendante peut-il faire ? (3) Pourquoi les attaquants envoient-ils ce message à des milliers de personnes ?

**✔ Corrigé**
(1) Signaux : le lien raccourci masque la vraie destination ; le message exige un paiement pour « débloquer » un colis déjà payé, ce qui n'est pas le fonctionnement normal d'un transporteur ; le ton crée une urgence ; l'expéditeur est un numéro ou une adresse inhabituels. La coïncidence n'est pas une preuve : les livraisons sont si fréquentes qu'un message envoyé au hasard « tombe juste » pour beaucoup de gens. (2) Vérification indépendante : ouvrir soi-même le site ou l'application officiels du transporteur et y saisir le numéro de suivi reçu lors de l'achat ; ou appeler le service client au numéro figurant sur le site officiel — jamais via le lien du SMS. L'état réel du colis y apparaîtra, sans les prétendus frais. (3) Parce que l'ingénierie sociale est un jeu de volumes : un taux de réussite minuscule suffit. Si une personne sur mille paie, dix mille messages rapportent dix paiements ; la défense consiste donc à faire partie des 999 qui vérifient — et à signaler le message pour protéger les autres.

# Travaux dirigés (TD)

## TD 1 — Plan de défense d'une petite agence

Une agence de transfert et de services de quartier emploie 6 personnes : un poste d'accueil connecté à Internet, un poste comptable avec les dossiers clients, une imprimante partagée, une box Internet grand public et un fichier de suivi stocké « sur le poste de la responsable, qui fait des sauvegardes quand elle y pense ». Aucun incident n'a encore eu lieu, mais la direction veut « faire quelque chose » avec un petit budget. Construis un plan de défense en trois parties : (1) trois risques majeurs du scénario, formulés menace + vulnérabilité + propriété CID ; (2) sept mesures concrètes classées par priorité, en précisant pour chacune le risque qu'elle réduit ; (3) deux règles simples à écrire dans une mini-politique de sécurité d'une page.

**✔ Corrigé du TD 1**
(1) Risques majeurs. R1 : un rançongiciel entré par une pièce jointe chiffre le fichier de suivi et les dossiers clients — menace : malware diffusé par courriel ; vulnérabilité : copie unique des données et sauvegardes irrégulières ; propriété : disponibilité. R2 : vol des identifiants bancaires/du service de transfert par hameçonnage — vulnérabilité : personnel non sensibilisé, mots de passe partagés ; propriété : confidentialité. R3 : attaque de la box ou du réseau local — vulnérabilité : réglages par défaut, Wi-Fi en ancien protocole ; propriété : intégrité et confidentialité. (2) Mesures prioritaires : 1) sauvegarde quotidienne automatique selon la règle 3-2-1, dont une copie hors ligne, avec test de restauration mensuel (R1) ; 2) mots de passe longs et uniques par personne, fin des comptes partagés, double authentification partout où elle existe (R2) ; 3) sensibilisation de 30 minutes de tout le personnel avec exemples de messages frauduleux, et règle « vérifier par un autre canal » (R2) ; 4) mises à jour automatiques des systèmes et de l'antivirus sur les deux postes (R1, R3) ; 5) box sécurisée : WPA3/WPA2, mot de passe admin changé, WPS désactivé, réseau invités pour les clients (R3) ; 6) comptes utilisateurs simples (non administrateurs) pour le travail quotidien (R1, R2) ; 7) pare-feu activé sur les postes, partage de fichiers limité au dossier nécessaire (R3). Toutes sont gratuites ou presque : le premier budget de sécurité est du temps et de la méthode. (3) Mini-politique : « Aucun mot de passe ne se partage ; tout message demandant un code ou un paiement urgent se vérifie par un autre canal avant toute action » et « Toute anomalie (message suspect, fichier étrange, lenteur inhabituelle) est signalée le jour même à la responsable, sans sanction pour celui qui signale ».

## TD 2 — Intégrité et mots de passe : l'atelier des empreintes

On te donne les empreintes SHA-256 réelles suivantes, calculées avec Python (hashlib) : A = empreinte de « Bonjour IAM » : 9a8c61830f4b5d7a636ba5848313dc8adc17354ef72dc6a2c8dae70c90e8b240 ; B = empreinte de « Bonjour IAM! » : 1250e81afdc4f4de2a39d3184fc42d1de88f0a3aced27dfb66dd5b4e04a44c08 ; C = empreinte de « IAM » : 7c6826445eb63c221233eae6d2d98f14b6b9e5b50abb9eefc83fc967dfa28382. (1) Un serveur conserve l'empreinte A comme référence du message attendu ; il reçoit un message dont l'empreinte calculée est B. Que décide-t-il, et pourquoi est-il impossible de dire « le message reçu est presque le bon » à partir des empreintes ? (2) Un attaquant vole une base contenant uniquement l'empreinte C. Peut-il « déchiffrer » C pour retrouver le texte d'origine ? Que peut-il essayer d'autre, et pourquoi le sel rend-il cette tentative beaucoup plus coûteuse ? (3) Pourquoi la comparaison des empreintes ne prouve-t-elle pas, à elle seule, qu'un fichier vient bien de son éditeur officiel ?

**✔ Corrigé du TD 2**
(1) Le serveur rejette le message : les empreintes A et B diffèrent, or SHA-256 est déterministe — le même message aurait donné exactement A. L'effet avalanche implique qu'on ne peut rien conclure de la « distance » entre deux empreintes : B correspond ici à un message différant d'un seul caractère, mais l'empreinte ne le révèle pas ; deux messages sans rapport produisent des empreintes tout aussi différentes. La règle est binaire : égales = contenu identique ; différentes = contenu différent, sans nuance. (2) Non : le hachage est à sens unique, il n'existe pas d'opération inverse ni de clé de « déchiffrement ». L'attaquant peut en revanche deviner des candidats, les hacher et comparer — c'est l'attaque par dictionnaire/force brute, redoutablement efficace sur des mots courts ou courants, surtout avec un algorithme rapide comme MD5 ou SHA-256 utilisé tel quel pour des mots de passe. Le sel — une valeur aléatoire différente pour chaque compte, mélangée avant le hachage — rend les empreintes uniques même pour des mots de passe identiques et invalide les tables précalculées ; combiné à une fonction lente (bcrypt, Argon2), il rend l'essai massif économiquement absurde. (3) Parce qu'une empreinte atteste un contenu, pas une origine : n'importe qui peut calculer l'empreinte d'un fichier, y compris d'un fichier piégé, et la publier sur un faux site. La garantie vient du canal : l'empreinte doit être obtenue depuis la source officielle (site de l'éditeur en HTTPS), et pour une preuve d'origine renforcée, on utilise une signature numérique de l'éditeur, vérifiable avec sa clé publique.

# Travaux pratiques (TP)

## TP 1 — Audit défensif de son propre poste et de son Wi-Fi (sur ses machines uniquement)

Ce TP se réalise exclusivement sur ton propre ordinateur et ton propre réseau, ou sur les machines du laboratoire mises à disposition par l'enseignant. Étapes : (1) relève la version de ton système et vérifie que les mises à jour automatiques sont activées ; (2) vérifie que le pare-feu logiciel est actif et note deux règles qu'il applique ; (3) lance une analyse antivirus complète et consigne le résultat ; (4) télécharge un petit fichier depuis un site qui publie son empreinte SHA-256, calcule l'empreinte avec Python (hashlib) ou la commande sha256sum / certutil -hashfile, et compare ; (5) connecte-toi à l'interface de ta box (ou décris celle du laboratoire) et relève : protocole Wi-Fi utilisé, WPS activé ou non, existence d'un réseau invités, ancienneté du firmware ; (6) rédige un rapport d'une page : constat, risques, corrections proposées classées par priorité.

**✔ Attendus du TP 1**
Attendus : (1) le rapport cite la version exacte du système et la preuve (capture ou menu) que les mises à jour automatiques sont actives. (2) Le pare-feu est actif sur les profils réseau ; les deux règles relevées sont expliquées en langage clair — par exemple « les connexions entrantes non sollicitées sont bloquées ». (3) L'analyse antivirus est complète (pas seulement « rapide ») et son résultat est consigné même s'il est négatif. (4) L'empreinte calculée est reproduite dans le rapport avec la commande utilisée ; la conclusion « identique/différente » est explicite — un écart doit conduire au rejet du fichier et à un nouveau téléchargement depuis la source officielle. (5) Le relevé Wi-Fi mentionne le protocole (WPA3/WPA2 attendu ; WEP ou WPA signalés comme non conformes), l'état du WPS (désactivé attendu) et l'existence du réseau invités. (6) Le rapport conclut par trois corrections prioritaires maximum, chacune reliée à un risque du cours (CID, moindre privilège, défaut de configuration). Barème indicatif : exactitude des relevés 40 %, justesse des calculs d'empreinte 25 %, qualité et priorisation des corrections 35 %. Tout test sur un réseau ou une machine ne t'appartenant pas est hors périmètre et interdit.

# Exercices corrigés supplémentaires

## Exercice 1

Chiffrement de César : (1) déchiffre le message « AMJM » sachant qu'il a été chiffré avec un décalage de 4 et qu'il parle de réseau ; (2) explique pourquoi connaître l'algorithme ne suffit pas à protéger un message moderne, et ce qui, dans AES ou RSA, remplace avantageusement le « secret de la méthode ».

**✔ Corrigé**
(1) On recule chaque lettre de 4 positions : A→W, M→I, J→F, M→I : le message est « WIFI ». (2) Le chiffrement de César n'a que 25 clés : connaître la méthode laisse un espace de recherche minuscule. Les algorithmes modernes appliquent le principe de Kerckhoffs : la méthode est publique, examinée et débattue par les experts du monde entier, et la sécurité repose uniquement sur la clé, choisie dans un espace immense (une clé AES de 128 bits offre 2^128 combinaisons : les essayer toutes est physiquement hors de portée). La sécurité ne vient donc pas de l'obscurité de la méthode, mais de la taille de l'espace des clés et de la qualité publique de l'algorithme.

## Exercice 2

Vrai ou faux ? Justifie en une ou deux phrases : (a) « Hacher un mot de passe avec SHA-256 suffit à le stocker correctement. » (b) « Si je chiffre un fichier avec la clé publique de quelqu'un, il est le seul à pouvoir le lire. » (c) « Un pare-feu rend l'antivirus inutile. » (d) « Un réseau Wi-Fi en WPA2 avec le mot de passe "soleil123" est bien protégé. »

**✔ Corrigé**
(a) Faux. SHA-256 est conçu pour être rapide : un attaquant muni de la base volée peut tester des milliards de candidats. Il faut un sel unique par compte et une fonction lente spécialisée (bcrypt, Argon2). (b) Vrai. Le déchiffrement exige la clé privée correspondante, que le destinataire est seul à détenir — à condition bien sûr que cette clé privée n'ait pas été compromise et que la clé publique utilisée soit bien la sienne (d'où les certificats). (c) Faux. Le pare-feu filtre le trafic réseau, l'antivirus surveille fichiers et comportements sur la machine : ce sont deux couches complémentaires de la défense en profondeur, pas des substituts. (d) Faux. « soleil123 » est un mot du dictionnaire suivi de chiffres : il tombe vite sous les essais automatisés, et même un excellent protocole ne compense pas une clé faible. Il faut une phrase longue, unique et imprévisible.

### Exercice 3

Un ami t'écrit : « Mon opérateur m'a appelé pour un problème de facturation ; il m'a demandé le code à 6 chiffres que je venais de recevoir par SMS pour "vérifier mon identité". Je le lui ai donné, et depuis, je n'ai plus accès à mon compte de messagerie. » Explique ce qui s'est probablement passé, pourquoi le code ne devait jamais être communiqué, et donne-lui les quatre actions à entreprendre immédiatement.

**✔ Corrigé**
Ce qui s'est passé : l'appelant n'était pas l'opérateur mais un attaquant en pleine ingénierie sociale. Il avait déjà déclenché une demande de réinitialisation ou de connexion sur le compte de messagerie de la victime — d'où le SMS bien réel — et il lui manquait le code de double authentification, qu'il s'est fait dicter en se faisant passer pour un service officiel. Le code ne doit jamais être communiqué : il est strictement personnel, aucun service ne le demande par téléphone ; le taper soi-même dans l'écran officiel est son seul usage légitime. Actions immédiates : (1) tenter de récupérer le compte par la procédure officielle de récupération depuis un appareil sain, et changer le mot de passe ; (2) activer/vérifier la double authentification et régénérer les codes de secours ; (3) vérifier les paramètres du compte (adresses de transfert, règles de filtrage, sessions ouvertes) et fermer toutes les autres sessions ; (4) prévenir ses contacts qu'un fraudeur peut se faire passer pour lui, et changer par précaution les mots de passe des comptes qui partageaient le même. La leçon : un code reçu par SMS se lit, se tape soi-même, mais ne se dicte jamais.

## QCM d'évaluation

Choisis la bonne réponse pour chaque question. Les corrigés détaillés se trouvent juste après le QCM : ne les regarde qu'après avoir répondu à tout.

1. Le risque, en sécurité informatique, se définit comme…

   A) Le nombre de virus détectés sur une machine

   B) La probabilité qu'une menace exploite une vulnérabilité, multipliée par l'impact

   C) Le prix d'un bon antivirus

2. Quelle propriété le déni de service attaque-t-il en premier ?

A) La confidentialité

B) L'intégrité

C) La disponibilité

3. Un ver informatique se distingue d'un virus principalement parce qu'il…

A) Se propage tout seul de machine en machine, sans fichier hôte ni clic

B) Est toujours inoffensif

C) Ne touche que les téléphones

4. Face à un rançongiciel qui a chiffré tes fichiers, la conduite recommandée est…

A) Payer vite pour récupérer la clé

B) Isoler la machine, ne pas payer, restaurer les sauvegardes saines

C) Éteindre et rallumer plusieurs fois en espérant

5. Dans le chiffrement asymétrique, pour t'envoyer un message confidentiel, on chiffre avec…

A) Ta clé privée

B) Ta clé publique

C) La clé privée de l'expéditeur

6. Une signature numérique est produite avec…

A) La clé privée du signataire, et vérifiée avec sa clé publique

B) La clé publique du destinataire

C) Un mot de passe partagé

7. Le hachage SHA-256 d'un message…

A) Peut être déchiffré avec la bonne clé

B) Est une empreinte à sens unique : on ne peut pas retrouver le message

C) Compresse le message pour l'envoyer plus vite

8. Deux fichiers ont des empreintes SHA-256 différentes. On peut conclure que…

A) Ils sont presque identiques

B) L'un est forcément un virus

C) Leur contenu est différent, ne serait-ce que d'un bit

9. La posture la plus sûre pour un pare-feu est…

A) Tout autoriser sauf une liste de blocages

B) Tout bloquer par défaut et autoriser explicitement le nécessaire

C) Ne filtrer que le trafic sortant

10. Pour le Wi-Fi d'un domicile, le meilleur choix est…

A) WPA3 (ou WPA2 à défaut), mot de passe long et unique, WPS désactivé

B) WEP avec un mot de passe compliqué

C) Réseau ouvert mais SSID caché

## Corrigés du QCM

1. Réponse B — Risque = probabilité × impact. On réduit le risque en corrigeant les vulnérabilités et en limitant les dégâts possibles.

2. Réponse C — Le déni de service sature la cible pour la rendre inutilisable : c'est la disponibilité du triptyque CID qui est visée.

3. Réponse A — Le ver exploite les failles réseau pour se diffuser de façon autonome ; le virus a besoin d'un hôte et, souvent, d'une exécution par l'utilisateur.

4. Réponse B — Payer ne garantit rien et finance la criminalité. La restauration depuis des sauvegardes saines (dont une copie hors ligne) est la parade prévue.

5. Réponse B — La clé publique du destinataire chiffre ; seule sa clé privée, qu'il garde secrète, peut déchiffrer.

6. Réponse A — Signer = clé privée de l'auteur ; vérifier = sa clé publique. Cela prouve l'origine et l'intégrité, sans rien cacher.

7. Réponse B — Le hachage n'est pas un chiffrement : pas de clé, pas d'opération inverse. Il sert à sceller (intégrité), pas à cacher.

8. Réponse C — SHA-256 est déterministe : des contenus identiques donneraient des empreintes identiques. Toute différence d'empreinte prouve une différence de contenu.

9. Réponse B — Le moindre privilège réseau : ce qui n'est pas nommé comme nécessaire reste fermé, y compris les services installés par erreur.

10. Réponse A — WEP est cassé et un réseau ouvert n'offre aucun chiffrement du lien. WPA3/WPA2 + phrase de passe longue + WPS désactivé = la base saine.

## Résumé — les notions importantes

• Risque = probabilité (menace × vulnérabilité) × impact ; les attaques visent la confidentialité, l'intégrité, la disponibilité.

• Malwares : virus (hôte), ver (autonome), cheval de Troie (déguisé), rançongiciel (extorsion), espion, rootkit ; la désinfection suit une procédure : isoler, analyser, réinstaller si besoin, restaurer, changer les mots de passe.

• Chiffrement symétrique (AES) : une clé partagée, rapide, mais échange délicat ; asymétrique : publique pour chiffrer, privée pour déchiffrer et signer.

• HTTPS combine les deux : l'asymétrique échange une clé de session, le symétrique chiffre la conversation.

• Hachage SHA-256 : empreinte fixe, déterministe, irréversible, effet avalanche ; il scelle (intégrité), il ne cache pas. MD5 et SHA-1 sont à abandonner.

• Mots de passe stockés : empreinte + sel unique + fonction lente (bcrypt, Argon2) — jamais en clair, jamais en MD5.

• Défense en couches : pare-feu « tout bloquer par défaut », antivirus à jour, politique de sécurité et moindre privilège, Wi-Fi WPA3/WPA2 bien configuré, utilisateurs formés contre l'ingénierie sociale.

## Vidéos associées aux leçons

Ces vidéos, en français, complètent les leçons. Liens vérifiés au moment de la publication de ce document.

### Leçon 1 — Cours 3 – Les principales menaces en cybersécurité

Chaîne : Mr REWINDE JEAN | Cybersécurité · Langue : Français · Niveau : L2 — début du cours

Un cours clair qui passe en revue les menaces les plus courantes — hameçonnage, virus, chevaux de Troie, rançongiciels, mots de passe faibles et systèmes non mis à jour. Parfait pour fixer le vocabulaire de la leçon 1 avant d'entrer dans le détail.

https://www.youtube.com/watch?v=Sjp996XQMMw

### Leçon 2 — Tous les virus informatiques expliqués en 11 minutes

Chaîne : RYXACORE · Langue : Français · Niveau : L2 — débutant à intermédiaire

La grande famille des malwares présentée de façon visuelle : virus, ver, cheval de Troie, rançongiciel, rootkit et réseaux de machines zombies, avec leurs portes d'entrée et les gestes de protection. Un complément idéal à la leçon 2.

https://www.youtube.com/watch?v=VBsU2blmK6Y

### Leçon 3 — Le chiffrement symétrique - AES expliqué

Chaîne : Mickaël Dupont · Langue : Français · Niveau : L2 — intermédiaire

Comment fonctionne AES, l'algorithme symétrique de référence : ses étapes internes sont expliquées pas à pas avec des schémas. À regarder après la leçon 3 pour voir ce qui se passe réellement derrière le mot « chiffrer ».

https://www.youtube.com/watch?v=5ZEYKk8BHcE

### Leçon 3 — Comprendre la cryptographie par la pratique avec OpenSSL

Chaîne : alumbo · Langue : Français · Niveau : L2 — intermédiaire

La cryptographie asymétrique en pratique : génération d'une paire de clés RSA avec OpenSSL, chiffrement avec la clé publique et déchiffrement avec la clé privée. Tu y verras concrètement les rôles exacts de chaque clé.

https://www.youtube.com/watch?v=MdVpxNHDXtc

### Leçon 4 — Cryptographie, chiffrement et hachage : comment ça marche ? | PKI, openssl

Chaîne : Techno · Langue : Français · Niveau : L2 — intermédiaire

Un tour complet et démonstratif : chiffrement symétrique et asymétrique, fonctions de hachage et infrastructure à clés publiques, avec des manipulations sous OpenSSL. Idéal pour relier les leçons 3 et 4 et ne plus confondre chiffrer et hacher.

https://www.youtube.com/watch?v=NJT4g5gu50c

## Sources et références


- Programme officiel Licence Informatique, Université IAM (Institut Africain de Management), Bamako — vérifier les intitulés d'UE auprès du secrétariat pédagogique.
- ANSSI (Agence nationale de la sécurité des systèmes d'information) — « Guide d'hygiène informatique » : les règles de base de la sécurité des postes et des réseaux, en accès libre sur ssi.gouv.fr.

• Cybermalveillance.gouv.fr — assistance et conseils aux victimes, fiches réflexes sur les rançongiciels, l'hameçonnage et la sécurisation des appareils.

• CNIL (cnil.fr) — guides sur les mots de passe, la sécurité des données personnelles et les obligations des organisations.

• Documentation officielle Python — module hashlib (docs.python.org/fr) : pour reproduire les calculs d'empreintes de la leçon 4.

• Les vidéos listées dans la section « Vidéos associées aux leçons » de ce document (liens vérifiés à la publication).

Fin du cours — Bronbah Tech, Bibliothèque Universitaire IAM. Bon courage pour tes révisions !